

Acme Accounts — Engineering Security Policy

v1.2

1. Scope

This policy applies to every service in the Acme Accounts platform, including the login service in this repository. It is maintained by the Platform Security team.

2. Authentication code

Changes to `app/auth.py` require a review by the security team before they are merged. Password comparison must remain constant-time.

3. Dependencies

Services must use only the Python standard library. New third-party dependencies require written approval from Platform Security.

4. Testing

Every behavior change must ship with a test that fails without the change. Tests that do not assert on the changed behavior do not count.

5. Incident history

In 2025 a rate-limit bypass in a sister service went unnoticed for three weeks because its tests only exercised the happy path.